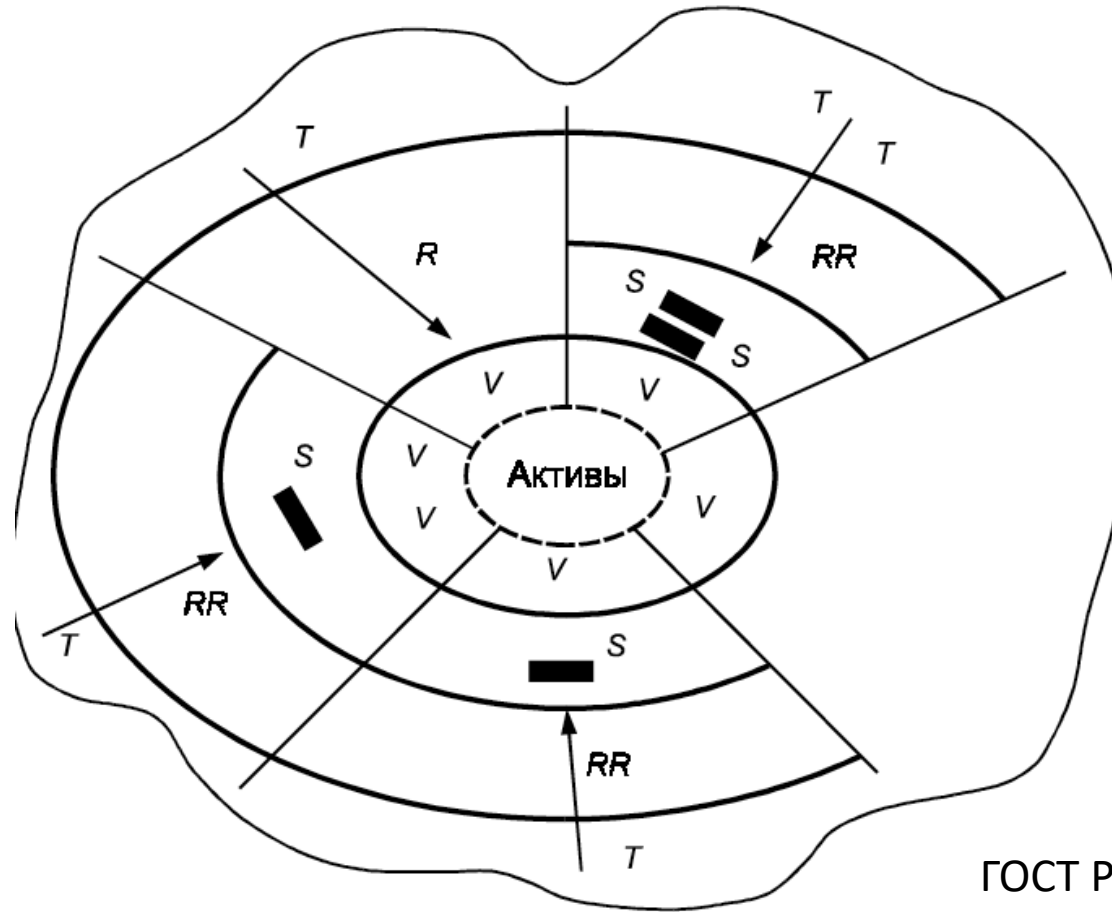


МЕТОДЫ И СРЕДСТВА ОБЕСПЕЧЕНИЯ БЕЗОПАСНОСТИ

Промыслов Виталий Георгиевич

vitaly.promyslov@gmail.com

Общие проблемы оценки риска



ГОСТ Р ИСО/МЭК Р 13335-1 2006

Управление риском:



Каталоги методов и мер защиты

1. Международные:

1. МЭК 15408-2
2. ГОСТ Р ИСО/МЭК 27002
3. МЭК 62443-2-1
4. IEC 63096
5. IEC 62443-3-3

2. Национальные

1. РФ:

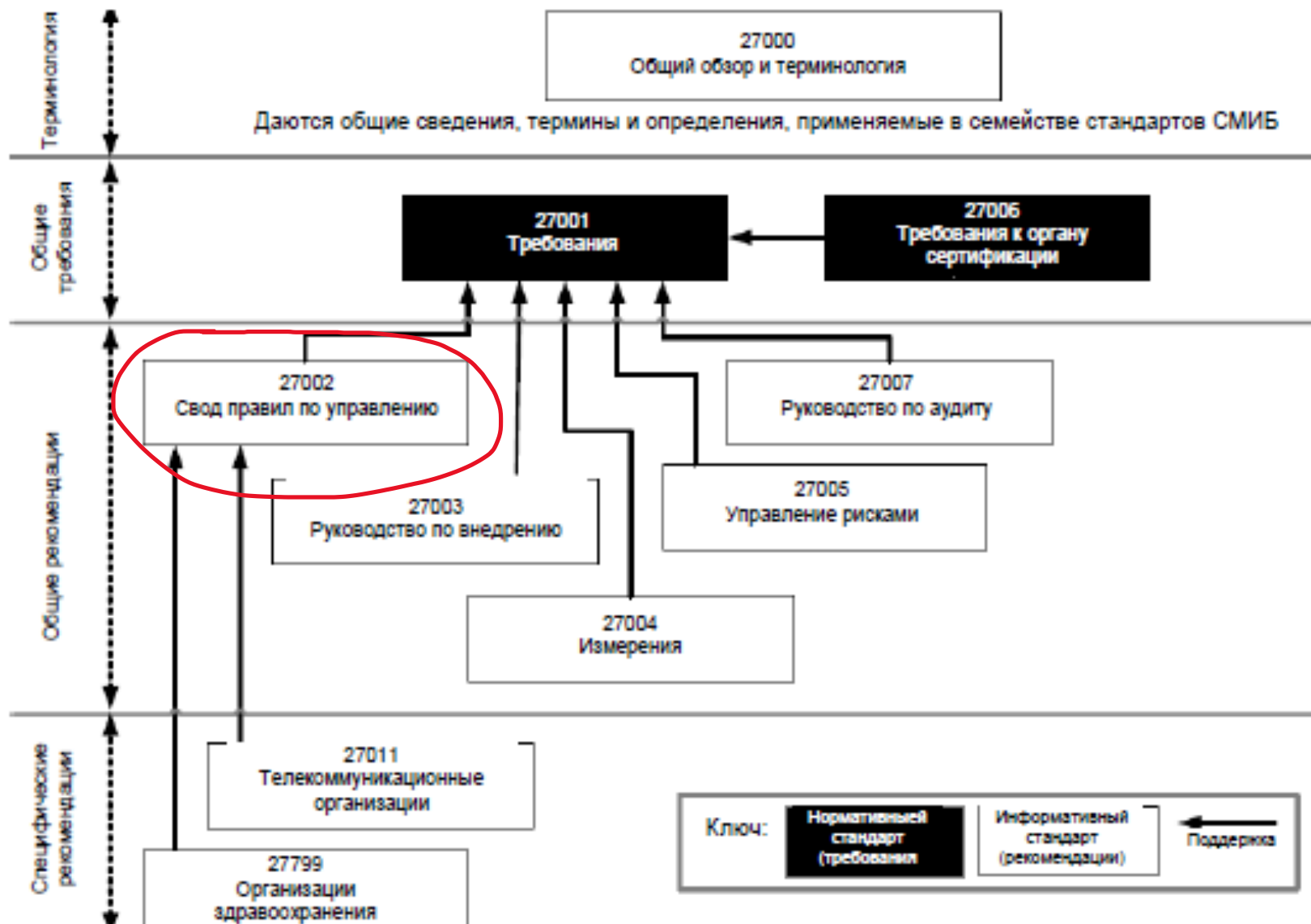
1. Автоматизированные системы. Защита от несанкционированного доступа к информации Классификация автоматизированных систем и требования по защите информации Утверждено решением председателя Государственной технической комиссии при Президенте Российской Федерации от 30 марта 1992 г.
2. ФСТЭК ПРИКАЗ от 25 декабря 2017 г. N 239 ОБ УТВЕРЖДЕНИИ ТРЕБОВАНИЙ ПО ОБЕСПЕЧЕНИЮ БЕЗОПАСНОСТИ ЗНАЧИМЫХ ОБЪЕКТОВ КРИТИЧЕСКОЙ ИНФОРМАЦИОННОЙ ИНФРАСТРУКТУРЫ РОССИЙСКОЙ ФЕДЕРАЦИИ (В РЕД. ПРИКАЗОВ ФСТЭК РОССИИ ОТ 9 АВГУСТА 2018 Г. N 138, ОТ 26 МАРТА 2019 Г. N 60, ОТ 20 ФЕВРАЛЯ 2020 Г. N 35)
3. Приказ ФСТЭК 31 от 14 марта 2014 г. N 31 ОБ УТВЕРЖДЕНИИ ТРЕБОВАНИЙ К ОБЕСПЕЧЕНИЮ ЗАЩИТЫ ИНФОРМАЦИИ В АВТОМАТИЗИРОВАННЫХ СИСТЕМАХ УПРАВЛЕНИЯ ПРОИЗВОДСТВЕННЫМИ И ТЕХНОЛОГИЧЕСКИМИ ПРОЦЕССАМИ НА КРИТИЧЕСКИ ВАЖНЫХ ОБЪЕКТАХ, ПОТЕНЦИАЛЬНО ОПАСНЫХ ОБЪЕКТАХ, А ТАКЖЕ ОБЪЕКТАХ, ПРЕДСТАВЛЯЮЩИХ ПОВЫШЕННУЮ ОПАСНОСТЬ ДЛЯ ЖИЗНИ И ЗДОРОВЬЯ ЛЮДЕЙ И ДЛЯ ОКРУЖАЮЩЕЙ ПРИРОДНОЙ СРЕДЫ

2. США:

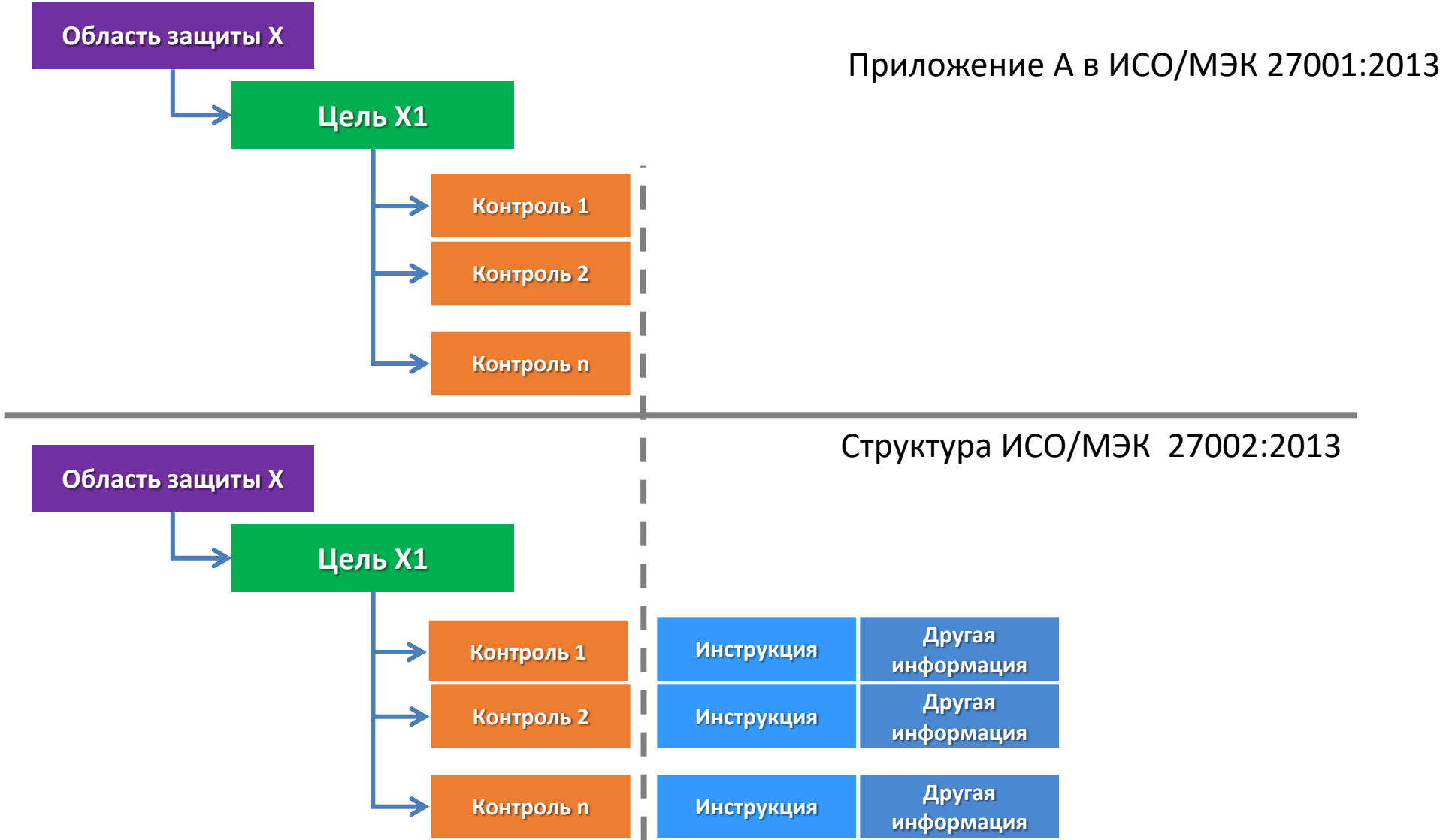
1. RG5.71 NRC
2. Orange book (TCSEC)

3.

Семейство стандартов СМИБ 27к



Связь между ИСО/МЭК 27001 и ИСО/МЭК 27002



Категории мер обеспечения информационной безопасности ГОСТ Р ИСО/МЭК 27002-2021

- Политики информационной безопасности
- Организация деятельности по информационной безопасности
- Безопасность, связанная с персоналом
- Менеджмент активов
- Управление доступом
- Криптография
- Физическая безопасность и защита от воздействия окружающей среды
- Безопасность при эксплуатации
- Безопасность коммуникаций
- Приобретение, разработка и поддержка систем
- Взаимоотношения с поставщиками
- Менеджмент инцидентов информационной безопасности
- Аспекты информационной безопасности в рамках менеджмента непрерывности деятельности организации
- Соответствие

Шаблон описания мер обеспечения информационной безопасности ГОСТ Р ИСО/МЭК 27002-2021

- Каждая основная категория содержит:
 - а) цель применения мер, которая содержит описание того, что должно быть достигнуто;
 - б) одну или несколько мер обеспечения ИБ, которые могут быть применены для достижения цели применения меры.
- Мера обеспечения ИБ
 - Определяет конкретную формулировку меры, направленную на достижение цели применения меры.
- Руководство по применению
 - Предоставляет более подробную информацию для помощи в реализации меры и достижения целей управления.
- Дополнительная информация

Пример Мера: Доступ к сетям и сетевым сервисам

- **Мера обеспечения ИБ:** Пользователям следует предоставлять доступ только к тем сетям и сетевым сервисам, на использование которых они получили конкретное разрешение.
- **Руководство по применению:** В отношении использования сетей и сетевых сервисов должна быть сформулирована политика. Эта политика должна охватывать:
 - а) сети и сетевые сервисы, к которым разрешен доступ;
 - б) процедуры авторизации для определения того, кому к каким сетям и сетевым сервисам разрешен доступ;
 - в) меры управления и процедуры для защиты доступа к сетевым соединениям и сетевым сервисам;
 - д) средства, используемые для доступа к сетям и сетевым сервисам (например, использование VPN или беспроводной сети);
 - е) требования к аутентификации пользователя для доступа к различным сетевым сервисам;
 - ф) мониторинг использования сетевых сервисов.
- Политика использования сетевых сервисов должна быть согласованной с политикой управления доступом организации (см. 9.1.1).
- **Дополнительная информация....**

ISO/IEC 27002-2022/Атрибуты Дополнение

- Типы управления (Control types)
 - Предупредить, Расследовать, Исправить
- Свойства безопасности (Information security properties)
 - Конфиденциальность, Целостность, Доступность
- Концепция (Cybersecurity concepts)
 - Защитить, Отследить, Восстановить и Отреагировать

ISO/IEC 27002-2022 /Атрибуты Дополнение

- Возможности применения (Operation capabilities)

Operational capabilities is an attribute to view controls from the practitioner's perspective of information security capabilities. Attribute values consist of Governance, Asset_management, Information_protection, Human_resource_security, Physical_security, System_and_network_security, Application_security, Secure_configuration, Identity_and_access_management, Threat_and_vulnerability_management, Continuity, Supplier_relationships_security, Legal_and_compliance, Information_security_event_management and Information_security_assurance.

- Подходы к безопасности (Security domains)

Security domains is an attribute to view controls from the perspective of information security domains, expertise, services and products. Attribute values consist of Governance_and_Ecosystem, Protection, Defence and Resilience.

ISO 27002 Пример/ Privileged access rights

Control type	Information security properties	Cybersecurity concepts	Operational capabilities	Security domains
#Preventive	#Confidentiality #Integrity #Availability	#Protect	#Identity_and_access _management	#Protection

Приказ ФСТЭК 31 от 14 марта 2014 г. Приложение 2 Требованиям к обеспечению защиты информации в автоматизированных системах управления производственными и технологическими процессами....

- Идентификация и аутентификация субъектов доступа и объектов доступа
- Управление доступом субъектов доступа к объектам доступа
- Ограничение программной среды (ОПС)
- Защита машинных носителей информации
- Регистрация событий безопасности
- Антивирусная защита
- Обнаружение вторжений
- Контроль (анализ) защищенности информации
- Обеспечение целостности
- Обеспечение доступности
- Защита среды виртуализации
- Защита технических средств
- Защита автоматизированной системы и ее компонентов
- Обеспечение безопасной разработки программного обеспечения
- Управление обновлениями программного обеспечения
- Планирование мероприятий по обеспечению защиты информации
- Информирование и обучение персонала
- Анализ угроз безопасности информации и рисков от их реализации
- Выявление инцидентов и реагирование на них
- Управление конфигурацией автоматизированной системы управления и ее системы защиты

РЕКОМЕНДАЦИИ ПО БЕЗОПАСНОЙ НАСТРОЙКЕ ОПЕРАЦИОННЫХ СИСТЕМ LINUX

(Утвержден ФСТЭК России 25 декабря 2022 г.)

- Рекомендации определяют содержание работ по настройке операционных систем на базе ядра Linux (далее — операционные системы Linux) и направлены на повышение защищенности информационных (автоматизированных) систем, построенных с использованием указанных операционных систем.
- Типы мер защиты:
 - Настройка авторизации в операционной системе;
 - Ограничение механизмов получения привилегий;
 - Настройка прав доступа к объектам файловой системы;
 - Настройка механизмов защиты ядра Linux;
 - Уменьшение периметра атаки ядра Linux;
 - Настройка средств защиты пользовательского пространства со стороны ядра Linux.

Меры безопасности специфичные для отрасли. Основные изменения

- Уточнение состава мер защиты (как в сторону добавления так и удаления)
- Руководство по реализации мер защиты с учетом используемых для защищаемой системы технологий
- Разделение мер защиты по уровням
- Привязка к жизненному циклу
- Выделение мер защиты нуждающихся в поддержке на уровне архитектуры защищаемой системы

Некоторые технических мер защиты (ИСО 27002, МЭК 62443)	Реализация Linux
Контроль доступа (в информационной системе)	Парольная мера защиты
Роли (функции) пользователя	Ограниченная реализация на группах UNIX
Доступ к и сетевым ресурсам и сервисам	iptables, capabilities
Управление доступом и аккаунтом пользователей	Администрирование пользователей
Использование привилегированных программ	Capabilities, SMACK
Зоны безопасности	Средства аутентификации и авторизации на компьютерах и сетевых устройствах
Контроль целостности	IMA/EVM + SMACK
Контроль ресурсов	audit + profiling
Ведение журнала событий	Audit, logs
Единая шкала времени событий	NTP
Процедуры контроля за установкой ПО	Пакетная система ???
Управление съемными носителями.	Capabilities, SMACK
Ограничения на запуск ПО	IMA/EVM + SMACK, capabilities
Контроль конфигурации оборудования и ПО	Ansible ???
Обеспечение безопасности связи (каналов передачи информации)	SMACK, iptables, шифрование
Резервируемость (избыточность)	Облачная архитектура, протоколы маршрутизации
Резервное копирование	+ tar
Виртуализация	KVM